Hybrid AI-based Detection of fileless malware in IOMT Healthcare systems

R26-CS-006

Project Proposal Report

Shakya W.A.R – IT22210142

B.Sc. (Hons) Degree in Information Technology Specialized in Cybersecurity

Department of Computer systems and Engineering

Sri Lanka Institute of Information Technology Sri Lanka

March 2026

Cross layer lateral movement correlation detection engine and XAI dashboard.

R26-CS-006

Project Proposal Report

Shakya W.A.R – IT22210142

B.Sc. (Hons) Degree in Information Technology Specialized in Cybersecurity

Department of Computer systems and Engineering

Sri Lanka Institute of Information Technology Sri Lanka

March 2026

DECLARATION

I declare that this is my own work, and this proposal does not knowingly incorporate any material previously submitted for a degree or diploma at any other university or higher education institution, nor does it contain any material that has been previously published or written by another person apart from where proper acknowledgment is given in the text.

Name	Student ID	Signature
Shakya W.A. R	IT22210142	
Fernando M.S. V	IT22080530	
Pagodaarachchi R. T.	IT22135070	
Chathuranga L.A. S	IT22108272	

The above candidate is conducting research for their undergraduate Dissertation under my supervision.

Name	Date	Signature
Mr. Kanishka Yapa.	13/03/2026	
Mr. Dinith Primal.	13/03/2026	

ABSTRACT (Maximum 300 words)

The rapid increase in the use of the internet of medical things devices in the healthcare sector has improved patient handling and care taking by enabling real time patient monitoring, automated diagnostics and enhanced medical data management [1]. However, this increased use and transformation of the internet of medical things devices have also increased the attack surface for the malicious parties, making the healthcare infrastructures vulnerable to sophisticated and complex cyber threats. Since most of the Internet of medical devices are running on the legacy systems and unpatched software models, this significant increase enables the attacker to easily infiltrate the healthcare infrastructure. Among these attacks fileless malware hold the least attention but has the life threating impacts, Because the fileless malware attacks operate entirely on systems memory and also in the legitimate operations tools like powershell, windows management instrumentation and also application programing interface, making the attacks almost impossible to detect by the device that uses traditions security mechanisms [2].

Currently active solutions are mainly focused on signature-based detection or one layer network detection methods. Which is inefficient in detecting stealthy attacks or malware like fileless behaviors and emerging threat patterns to prevent lateral movement on the networks [3]. As the solution for this real-world existing problem, this research presents a Ai-driven hybrid anomaly detection framework that is designed to improve the security state of healthcare sector devices against fileless malware attacks. This proposed framework contains multi-layer intelligent components that cover the networks layer for DICOM medical imaging traffic, end-point layer for Powershell based fileless malware detection, forecasting layer that gives that timeline for the next 24-hour time frame and a cross-layer correlation mechanism with a XAI dashboard to improve the decision making of the security analyst.

This proposed solution will be influenced by machine learning models, behavioral analysis, IOMT network traffic datasets like CICIomt dataset and real-world hospital network anonymous dataset to detect anomalies and to forecast plausible threats to a network before escalating into a critical cyberattack. Therefore, the expected outcome of this research is an intelligent and proactive security system that has the ability to detect threats at earlier stages, enhanced situational awareness that helps to strengthen the healthcare network and IOMT security.

Keywords: Internet of medical things, PowerShell, Windows management instrumentation, machine learning model , behavioral analysis , fileless malware ,Emerging threats.

ACKNOWLEDGEMENT

I would like to spare this section to give my gratitude to the colleagues and lecturers who have helped me through the proposal preparation of this research. First and foremost, I would like to give my thanks and gratitude to the supervisor and co-supervisor , Mr. Kanishka Yapa and Mr. Dinith Primal for their valuable guidance , constructive feedbacks , and continuous encouragement during the development of the topic and the proposal preparation, And also I would like to give my gratitude to Ms. Thriyashi Silva for helping us on narrowing down the topic specifications and giving us comments on the topic that we have created earlier stages of the research. Their expertise and insightful suggestions have major impact on selecting a proper research topic and for the component contributions.

Furthermore, I would like to give my gratitude to my team members for their support, discussions and valuable ideas, their collaboration has been greatly appreciated

TABLE OF CONTENT (Auto Generated)

DECLARATION ..... **Error! Bookmark not defined.**

ABSTRACT (Maximum 300 words) 4

ACKNOWLEDGEMENT 5

TABLE OF CONTENT (Auto Generated) 6

LIST OF TABLES 7

LIST OF FIGURES 8

LIST OF ABBREVIATIONS 9

LIST OF APPENDICES 10

1. INTRODUCTION 11

2. OBJECTIVE 17

3. METHODOLOGY 18

4. HIGH-LEVEL SYSTEM ARCHITECTURE 20

5. USER REQUIREMENTS 25

6. COMMERCIALIZATION PLAN 27

8. WORK BREAKDOWN STRUCTURE (WBS) 32

9. GANTT CHART 33

10. REFERENCES LIST 35

LIST OF TABLES

Table 1: Summary of Existing IoMT Security Research

Table 2: Comparison Between Existing Security Platforms and Proposed Framework

Table 3: Evaluation Metrics for System Performance

Table 4: Pricing Strategy for the Proposed Cybersecurity System

Table 5: Hardware Cost Estimation for Research Implementation

LIST OF FIGURES

Figure 1: Hybrid AI-Driven Multi-Layer Security Framework Workflow Diagram.

Figure 2: High-Level System Architecture of Component 4 – Cross-Layer Lateral Movement Correlation and XAI Dashboard with Vulnerability Assessment.

Figure 3: Work breakdown structure.

Figure 4: Overall Research Project Gantt Chart.

Figure 5: Component 4 Development Gantt Chart.

LIST OF ABBREVIATIONS

AI	Artificial Intelligence
API	Application Programming Interface
ATT&CK	Adversarial Tactics, Techniques and Common Knowledge
CVE	Common Vulnerabilities and Exposures
CVSS	Common Vulnerability Scoring System
DICOM	Digital Imaging and Communications in Medicine
GNN	Graph Neural Network
IDS	Intrusion Detection System
IoMT	Internet of Medical Things
IoT	Internet of Things
ML	Machine Learning
PACS	Picture Archiving and Communication System
SHAP	SHapley Additive exPlanations
SOC	Security Operations Center
WMI	Windows Management Instrumentation
XAI	Explainable Artificial Intelligence
XDR	Extended Detection and Response
SIEM	Security Information and Event Management

LIST OF APPENDICES

- Appendix A- Project Gantt Chart.
- Appendix C- Proposed System Architecture Diagram.
- Appendix E- System Workflow Diagram.

1. INTRODUCTION

1.1 Background and Context

The rapid technological advancement of the modern-day healthcare sectors has increased the usage of internet of medical things devices, where information sharing, patient monitoring, imaging systems and clinical networks operate as highly interconnected environment. This connectivity between the healthcare devices significantly improves the care delivery and operational efficiency, but this increased usage of the IOMT devices has also enlarged the attack surface of healthcare sector infrastructures. Recent studies show that the IOMT ecosystems have numerous security threats that include ransomware, unauthorized access, malware infections and complex multi-stage cyber-attacks that mainly target the patient's personal data [4], particularly fileless malware. Fileless malware mainly invades the victim systems by using the legitimate operation and runs on entirely systems memory. This is designed to abuse legitimate systems tools like PowerShell, application programming interface (API) and windows management instrumentation (WMI). Therefore, the traditional signature-based detection systems and mechanisms are ineffective when it comes to detecting fileless malware [4]. Once the initial access to the healthcare infrastructure is obtained, then the attacker could perform lateral movement across the network to gain access to more privileged devices, endangering the patient details and disrupting the operation workflow [5]. Recent reports on cyber security have shown that the healthcare sector is still facing the highest financial losses in comparison to other sectors in case of data breaches, and the average cost of a data breach in the healthcare sector is significantly higher than the global average [6]. In addition, reports on cyber security in different nations have shown an increasing number of cybercrimes against critical sectors of the nation.

In addressing this more general research problem, this study proposes a hybrid multi-component security framework for the detection and mitigation of advanced cyber threats in IoMT environments. The first component is focused on the detection of anomalies in DICOM medical imaging network communications for the early identification of abnormal behaviors in PACS-based medical networks. The second component is focused on the detection of PowerShell-based fileless malware activities at the endpoint level through behavior analysis techniques. The third component is focused on developing a predictive threat forecasting engine utilizing machine learning for the prediction of emerging attack patterns in IoMT network communications. Although these components are focused on the detection of cyber threats at different layers in a medical environment, they lack the ability to correlate attack behaviors at multiple layers in a healthcare infrastructure and provide a clear explanation for how these cyber threats spread in a healthcare infrastructure. As a result, this study proposes a fourth component for developing a Cross-Layer Lateral Movement Correlation and Explainable AI (XAI) Dashboard with Vulnerability Assessment for addressing more general research problems in a healthcare infrastructure [7],[8].

The current research is in line with the United Nations' Sustainable Development Goals, specifically goal 3: Good Health and Well-being, which aims to ensure healthy lives and promote well-being at all ages by enhancing the effectiveness of healthcare systems. By

enhancing the cybersecurity resiliency of IoMT in healthcare infrastructures, this research contributes to the overall goal of protecting critical healthcare services and enhancing patient safety. Moreover, this framework contributes to goal 9: Industry, Innovation and Infrastructure by promoting the development of digital technologies in healthcare services.

This research is in line with the Information Assurance and Security research cluster, specifically in ensuring the security of healthcare infrastructures and confidential medical information from sophisticated cyber-attacks in Internet of Medical Things (IoMT) ecosystems. The developed framework combines the use of artificial intelligence, machine learning, and cybersecurity techniques in the detection, analysis, and mitigation of sophisticated cyberattacks such as fileless malware and latera movement in healthcare ecosystem.

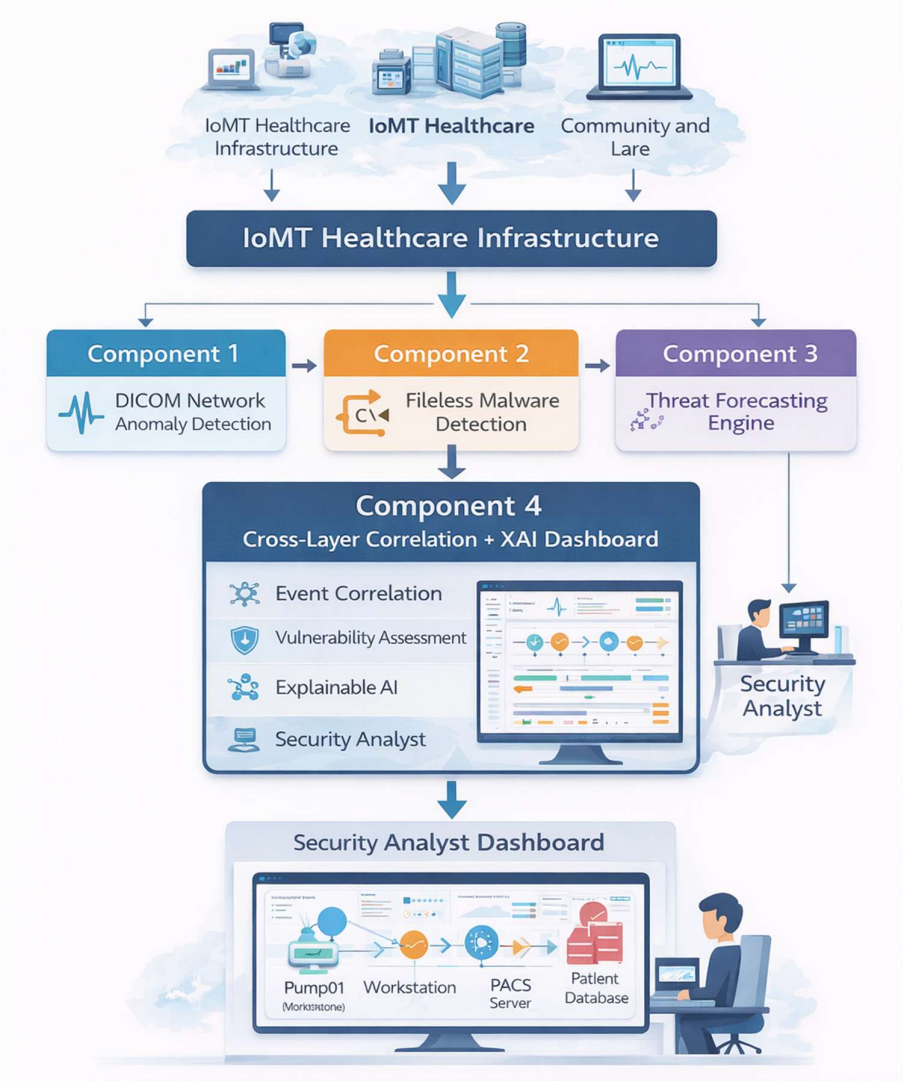


Figure 1: Hybrid AI-driven multi-layer security framework workflow diagram.

1.2 Literature Review (8–12 recent scholarly sources)

Recent literature indicates that the security of the IoMT environment is not simply achieved through the conventional intrusion detection system because the attacks in the environment are complex and involve multiple devices, networks, identities, and applications. Adil et al. have stated that the security of the healthcare IoT environment is threatened by various types of attacks, including malware attacks, unauthorized access attacks, ransomware attacks, and complex attacks involving multiple stages. Moreover, the authors have emphasized the difficulty in monitoring the security of the interconnected and heterogeneous environment of the healthcare system. This literature is helpful in understanding the overall threat scenario of the IoMT environment but is still a general study and does not provide a specific mechanism for the correlation of the lateral movement paths across different layers in the hospital environment [4]. Hady et al. have compared the medical data-based and network data-based intrusion detection systems for the security of the healthcare system and have concluded that the combination of multiple data types is effective in the IDS system but have not provided the study of the complex stages of the attack in the healthcare environment [9].

Significantly, much of the prior work has focused on the concept of advanced persistent threats and lateral movement. Alshamrani et al. note that lateral movement is a key part of the multi-step attack process, wherein the adversary uses “pivot points” from compromised hosts, accounts, and services in order to gain access to high-value assets. Their work also shows that this process is difficult to detect, since the activities performed by the adversary can be similar to those performed by system administrators and can be fragmented across multiple log sources [5]. This is, of course, also applicable to healthcare systems, wherein the adversary might be moving from a compromised workstation or IoMT device toward PACS servers, clinical systems, or patient data repositories. Nevertheless, much of the prior work provides little in the way of healthcare-specific frameworks that correlate this movement across multiple layers of the system in a way that is applicable to the analyst [4].

Another significant research direction is the application of machine learning in intrusion detection systems. Wang et al. presented an explainable machine learning framework that can be applied to intrusion detection systems and explained how it can improve the interpretability of the intrusion detection results [8]. In general, Adadi and Berrada’s “XAI Survey” and Capuano et al.’s “XAI Survey Focused on Cybersecurity Applications” both concluded that explainability is essential when the decisions made by the AI system have significant consequences and that the decisions must be trustworthy and verifiable rather than relying on the predictions made by the system [7], [10]. Zhang et al. also presented a review on the application of XAI in cybersecurity and how it can improve the transparency of the decision-making process [11]. However, the majority of the research on the application of XAI in cybersecurity is based on the explanation of the decision-making process rather than explaining the multi-stage movement through the infrastructure in the healthcare industry [8][11].

Vulnerability assessment is another prominent issue in literature. Malamas et al., in their paper, discuss IoMT risk assessment methodologies and demonstrate that in the context of

healthcare environments, it is necessary to use structured approaches to assess device exposures, weak configurations, communication risks, and operational impact [12]. Along these same lines, Almazrouei et al. discuss attack graph analysis for IoT vulnerability assessment and demonstrate that attack graph analysis is useful for IoT environments to assess vulnerabilities [13]. These papers are highly relevant to Component 4, as they demonstrate that it is not possible to separate the issue of vulnerability context from attack detection in IoMT environments. However, it appears that most of these papers are centered on risk modeling or representation, rather than integrating vulnerability context with real-time alert correlation and explainability in IoMT environments [12], [13].

Existing research methods can thus be broadly classified into four categories: healthcare/IoMT security methods, one-layer IDS and anomaly detection systems, XAI-based IDS models, and vulnerability or attack graphs-based methods. Although each of these methods has its own importance in tackling different facets of the problem, they all demonstrate one thing in common: existing methods are often designed for one layer of visibility or another. While a network IDS might detect anomalous network traffic, an endpoint IDS might see anomalous commands, and a vulnerability assessment platform might identify vulnerable assets, they are often designed in isolation and provide limited support for correlating the entire attack chain. This is particularly true in the healthcare domain, where a sophisticated threat actor might exploit a vulnerable asset, misuse credentials, move laterally, and compromise critical assets without triggering a single obvious alert trail.

Study	**Technique**	**Focus**	**Limitations**
Adil et al. (2024)	IoMT Security Survey	Healthcare IoT threats	No cross-layer detection
Hady et al. (2020)	IDS for Healthcare	Network + medical data	No attack chain analysis
Wang et al. (2020)	Explainable IDS	ML explainability	No multi-stage attack explanation
Malamas et al. (2021)	IoMT Risk Assessment	Vulnerability analysis	Not integrated with detection

Table 1: Summary of Existing IoMT Security Research

As for existing products and services, it should be mentioned that existing enterprise security platforms are partially capable of providing some of the functionality for this component. For instance, Microsoft Defender XDR provides unified visibility for endpoints, identities, email, applications, and IoT devices, whereas its automated attack disruption features are intended to restrict lateral movement in the very early stages of an attack [14], [15]. Additionally, Splunk

Enterprise Security provides risk-based alerting and contextual risk analysis to prioritize high-fidelity threats for investigation [16], [17]. Moreover, Palo Alto Cortex XDR and Cortex XSIAM provide causality views and cross-sensor event stitching to illustrate process execution chains and correlated alert timelines [18], [19]. These platforms demonstrate the effectiveness of cross-domain investigation and causality analysis but are primarily commercial solutions for SOCs for general environments, rather than research-oriented IoMT-specific solutions for healthcare environments.

Based on this literature, the primary deficiency in the current systems is not the lack of detection tools but the lack of an integrated mechanism in the field of healthcare that combines four aspects at once. Therefore, the proposed Component 4 aims at addressing this deficiency by developing a cross-layer lateral movement correlation + XAI dashboard with vulnerability assessment. This makes the component novel in the overall framework because it attempts to move beyond the detection mechanism and enter the realm of healthcare-oriented understanding and response support.

System	Cross-layer Detection	XAI	Vulnerability Context	Healthcare Focus
Microsoft Defender XDR	✓	✗	✓	✗
Splunk ES	✓	✗	✓	✗
Cortex XDR	✓	✗	✓	✗
Proposed Framework	✓	✓	✓	✓

Table 2: Comparison Between Existing Security Platforms and Proposed Framework

1.3 Research Gap

Clear state of what is missing

While existing literature has addressed IoMT security, intrusion detection, XAI, and vulnerability assessment, there still remains a need for a mechanism that is specifically adapted to the healthcare domain and capable of integrating evidence of attacks at different levels of the infrastructure to detect lateral movement in a manner that is easily understood. Existing literature primarily focuses on security from different but limited viewpoints, such as network monitoring, endpoint detection, or risk assessment, but fails to adequately integrate these different viewpoints to provide a singular framework for detecting lateral movement across interconnected medical systems [4]. Moreover, although XAI-based IoMT intrusion detection systems have enhanced explainability, existing literature primarily focuses on explaining individual alerts or classification results rather than explaining the entire process of a multi-stage attack across interconnected medical systems [8].

Why Current Approaches Are Insufficient

First, current approaches are insufficient because, in a healthcare environment, advanced attacks are not constrained to a single layer of the infrastructure. An adversary might start with a compromised device, then leverage compromised credentials, traverse the infrastructure utilizing trusted communication paths, and eventually reach a high-value target such as a PACS server, patient database, or clinical workstation. A single-layer intrusion detection approach cannot fully recreate this sequence of events because they examine only a single source of information at any given time [5]. In addition, several IoMT vulnerability assessment studies identify the exposed resources as well as the weak states, but they are not necessarily incorporated into a real-time detection process or analyst investigation [12]. Consequently, current systems might identify potential threats, such as anomalous behaviors or vulnerable devices, but they are still not effective in terms of understanding the relationships between a series of activities, including vulnerabilities, suspicious activities, as well as lateral movements, within a healthcare infrastructure.

Justifying the novelty and creativity

The novelty of the proposed component can be justified by the fact that it has the capability to incorporate the concepts of cross-layer event correlation, lateral movement reasoning, vulnerability awareness, and explanation visualization into a single component that is focused on the healthcare domain. This component is not intended to be another intrusion detection component that operates independently; rather, it is intended to correlate the outputs of multiple layers within the overall framework and recreate the suspicious paths that an attacker has taken in the system. The creativity of the proposed component can be justified by the incorporation of the XAI dashboard, which not only informs the user that the detected intrusion is malicious in nature but also explains the reasons behind the generation of the intrusion, the assets that have been compromised, and the ways in which the attacker has compromised the system [8].

Evidence-based argument

Evidence supporting this part of the argument comes from previous works. According to IoMT security survey literature, health systems remain vulnerable to various cyber threats because of their heterogeneity and interconnections [4]. Advanced persistent threats literature points out that lateral movements are considered to be one of the most challenging phases of detection, as the activities of the attackers are usually similar to normal system activities, extending over a vast number of systems and services [5]. Health intrusion detection literature indicates that, in such complex systems, relying on a single data perspective limits detection capabilities [9]. On the other hand, literature regarding XAI-based IDS points out that, even though trust in IDS solutions depends on explanations, current explanations are mostly related to single events, not addressing the entire attack process [7]. Finally, literature regarding IoMT risk assessment indicates that understanding the context of the vulnerability is a critical factor in health systems, but this is not fully integrated with dynamic threat correlation, a critical factor in this context, which is not supported, a fact supporting the argument regarding Component 4, as this solution is missing.

2. OBJECTIVE

2.1 Main Objective (Measurable)

This section is all about designing the Cross-Layer Lateral Movement Correlation system with the added component of the Explainable AI (XAI) dashboard and the integration of vulnerability assessment into the system as a whole. The goal is to be able to detect and display multi-stage cyber-attacks in the IoMT world of healthcare settings by gathering security-related information from different sources and attempting to identify unusual patterns in the lateral movement and providing insights that can be easily understood.

2.2 Specific Objectives (4–6 measurable)

Objective 1

To collect and correlate security events across the entire spectrum of the healthcare infrastructure, including network traffic logs, system activity logs, authentication logs, and vulnerability scans, to facilitate inter-layer security analysis in IoMT systems.

Objective 2

To design and implement a cross-layer event correlation mechanism capable of identifying potential lateral movement patterns across interconnected IoMT devices and healthcare systems.

Objective 3

To develop a vulnerability-aware analysis module that incorporates vulnerability assessment results to identify high-risk assets and prioritize potential attack paths within healthcare networks

Objective 4

Use the XAI method to improve the explanations provided for the identified attacks and correlated security events. This will enhance the transparency and usability of the intrusion detection system based on the AI method.

Objective 5

Design an interactive security dashboard that displays correlated attack chains, system vulnerabilities, and lateral movements in the IoMT infrastructure. The purpose of this objective is to assist security analysts in better understanding and investigating cyber-attacks.

Objective 6

Evaluate how well the cross-layer correlation framework works on actual or simulated IoMT security data sets. Metrics for evaluating this include how accurately it detects security threats, how well it can reconstruct attack paths, and how interpretable the generated explanations are.

3. METHODOLOGY

Research approach

The study follows a System Development and Evaluation approach, which is a widely accepted methodology in information technology studies for developing and validating a new system to solve a problem in the real world. The aim of this part is to develop a Cross-Layer Lateral Movement Correlation and Explainable AI Dashboard, enriched with Vulnerability Assessment features for IoMT in healthcare settings.

The approach will be based on developing a proposed system, creating a prototype for the same, and evaluating how well it compares with existing systems in terms of security metrics. The success of this approach will be determined by how effectively it can identify lateral movement attacks in correlation with traditional single-layer monitoring systems. In addition to this, key research methods for conducting experiments on the effectiveness of correlation algorithms and explainable machine learning models will be incorporated in this study.

Technical methods and algorithms.

The component is designed to detect and analyze the cyber threats that occur across the layers in the health infrastructure through the integration of various technical strategies.

- **The first approach** is the application of the cross-layer correlation events. In this approach, we will correlate the security events that occur across the various layers in the system and analyze them. This will involve the application of rule-based and graph-based correlation mechanisms to determine the relationships that exist between the malicious activities that occur across the system.
- **The second approach** is the application of the attack graph modeling mechanism. This approach will enable us to determine the paths that an attacker could take through the IoMT devices and the infrastructure that connects them.
- **Lastly**, will apply the SHAP and LIME mechanisms as part of the application of the Explainable AI approach, which will enable us to gain insights into the security detection mechanisms that we have applied.

Tools and platforms (with justification)

- The proposed prototype will be achieved through the application and implementation of commonly used cybersecurity and machine learning technologies.
- The proposed language for the development process is Python, as it has many libraries that can be used for data analysis, machine learning, and cybersecurity.
- Some of the commonly used Python libraries that can be used to implement the proposed prototype include Scikit-learn, TensorFlow, and SHAP.
- For the data processing and analysis, the proposed prototype will utilize Pandas and NumPy to analyze the security events from multiple system layers.
- For the visualization and development of the proposed dashboard, the proposed prototype will utilize Plotly Dash and Grafana to create an interactive explainable AI

dashboard that can be used to display the correlated alerts, vulnerability information, and possible attacks.

- A virtual laboratory environment will be used to simulate the IoMT network environment and generate the test scenarios using the virtualization platforms such as VirtualBox and VMware.

Data collection and ethical considerations

The proposed system will be validated through the use of existing public cybersecurity datasets as well as simulated data based on the characteristics of the network traffic generated by IoMT devices in healthcare settings.

CIC IoMT dataset to replicate the network traffic generated by IoMT devices in healthcare settings. The dataset includes various types of attacks and network traffic that are relevant for testing the performance of the anomaly detection and attack correlation mechanism.

Will also generate authentication logs, system logs, and results from vulnerability scans in a lab environment to mimic real-world healthcare network scenarios.

Ethical Considerations:

The research will be carried out in an ethical manner. No real patient data and no personally identifiable medical information will be used in the research. All experiments will be conducted in a controlled environment and within the boundaries set by the use of publicly available datasets.

Validation strategy and metrics

The proposed system component will be evaluated using controlled experiments and measurable system performance metrics.

To begin with, we will design test scenarios that laterally move across healthcare systems in order to assess the ability of the system to recreate the attack paths. We will compare the system's ability to perform this function with baseline systems that use traditional detection methods, examining security events from a single layer.

The system's performance metrics include:

- Detection Accuracy
- Precision
- Recall
- F1 Score
- False Positive Rate
- Attack Path Reconstruction Accuracy
- Alert Interpretability

In addition, we will also perform functional tests on the system to ensure that the dashboard provides accurate visual representations.

This evaluation is intended to demonstrate whether the system for cross-layer correlation enhances the ability to detect and analyze complex cyber attacks in IoMT healthcare systems.

Metric	Purpose
Accuracy	Overall detection performance
Precision	Correct alerts ratio
Recall	Detection capability
F1 Score	Balance between precision and recall
False Positive Rate	Incorrect alerts
Attack Path Accuracy	Correct reconstruction of attack chains
Interpretability Score	clarity of XAI explanations

Table 3: Evaluation metrics.

4. HIGH-LEVEL SYSTEM ARCHITECTURE

4.1 Overview of the Proposed Solution and Its Components

The proposed component 4 introduces a cross-layer lateral movement correlation and explainable AI dashboard with vulnerability assessment, which is specifically designed for IoMT environments in healthcare settings. The main idea behind this component is to collect security events from different layers of the healthcare stack, correlate these events to detect suspicious lateral movement, identify high-risk assets, and provide comprehensible security information to analysts.

As part of the integration and decision-support component of the overall framework for conducting research, this component leverages detection results from different components of the framework at different levels of analysis, fusing these results with associated vulnerabilities and surrounding infrastructure to create a representation of possible attack scenarios in an interactive dashboard

The proposed architecture of Component 4 consists of the following main subcomponents:

1. **Data Ingestion Layer:** This part of the system gathers alerts, logs, and outputs of various network monitoring tools, endpoint detection systems, authentication logs, as well as vulnerability scans.
2. **Preprocessing and Normalization Module:** This part of the system cleans, filters, and normalizes the gathered data into a single format, allowing all parts of the system to analyze the data.

3. **Cross-Layer Correlation Engine:** This part of the system correlates security alerts coming from different parts of the system, showing the relationships between different alerts, as well as the different lateral movement paths of the attackers.
4. **Vulnerability Assessment Module:** This part of the system combines the results of the vulnerability scans with asset exposure information, showing the systems that are at great risk of being targeted by attackers.
5. **XAI Analysis Module:** This part of the system provides clear explanations of the correlated alerts as well as suspicious attack patterns, ensuring that they are understandable to humans.
6. **Visualization and Dashboard Layer:** This part of the system shows the attack paths, as well as the alerts, assets, vulnerabilities, and explanations of the XAI Analysis Module, which are used to make decisions.

4.2 System Diagram of Components

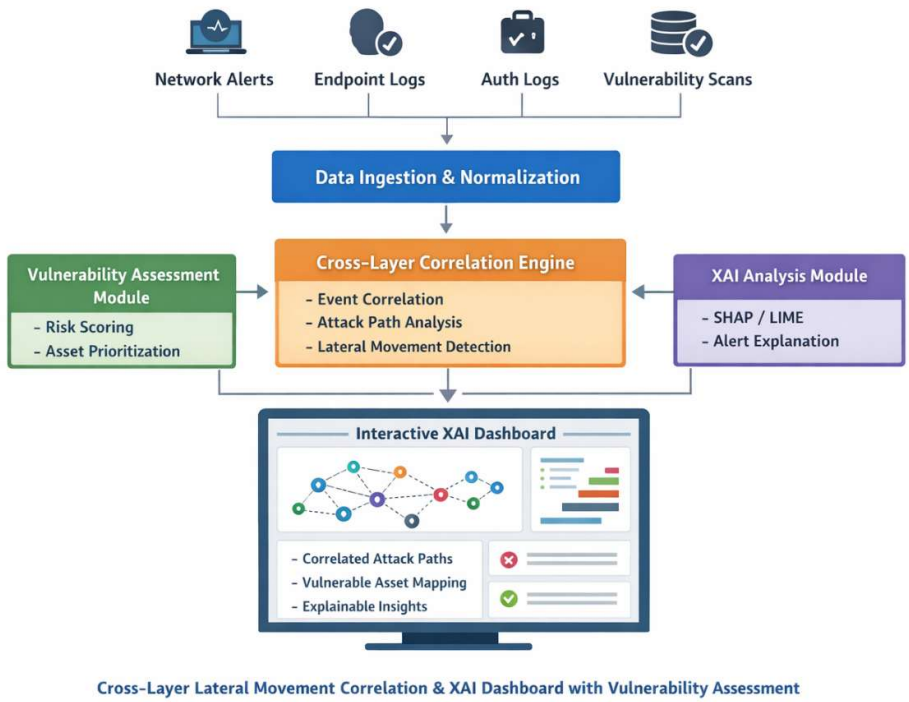


Figure 2: High-Level System Architecture of Component 4 – Cross-Layer Lateral Movement Correlation + XAI Dashboard with Vulnerability Assessment

4.3 Highlighting the Individual Component and Its Parts

Component 4 is comprised of the following:

a) Input Sources

The data sources for the component are:

- Anomaly reports from Component 1
- Endpoint and PowerShell behavior reports from Component 2
- Threat forecast reports from Component 3
- Authentication reports
- Vulnerability scan reports
- Asset metadata from the healthcare environment

b) Correlation Core

The main processing engine of the component is comprised of:

- Event matching
- Time-based linking
- Host to host relationship analysis
- Detection of suspicious sequence of events
- Lateral movement analysis

c) Vulnerability Context Layer

The results of the correlation engine are enhanced with the following:

- Detection of vulnerable assets
- Contextual checks for exploitability
- Ranking of critical attack paths

d) XAI Explanation Layer

The results are interpreted with the following:

- Explanation of the decision process for an alert chain
- Identification of key contributing features
- Highlighting of contributing events

e) Dashboard Layer

The final output of the component is comprised of:

- Attack paths
- Alert summaries
- Risk levels
- Visualization of vulnerable assets
- Interpretability for analysts

4.4 Component Interactions

Component 4 connects with the previous research components and the healthcare ecosystem.

- Component 1 sends network anomaly alerts related to DICOM and medical imaging communication.
- Component 2 sends endpoint anomaly alerts related to suspicious PowerShell usage or fileless malware activity.
- Component 3 sends predictions related to possible future threats or patterns of attack.
- The Vulnerability Assessment Module adds risk context related to exposed devices and systems.
- The Correlation Engine combines all the previous inputs and determines if the individual alerts are related to a single multi-stage attack.
- The XAI Module helps to understand the reasoning behind the correlated detection results.
- The Dashboard displays the final results to the analyst in a visual and easily understandable way.

This interaction allows the system to go beyond individual alert generation and provide a more holistic understanding of how the attacks are spreading through the healthcare ecosystem.

4.5 Data Flow Explanation

The data flow for Component 4 follows this process through five main stages.

1) Data Collection

- The security events, alerts, and results of scans are collected from different sources, including network traffic analysis, endpoint monitoring, authentication mechanisms, and vulnerability scans.

2) Data Preprocessing

- The data collected is then cleaned and normalized in a single form for analysis purposes. For example, time stamps, host IDs, user accounts, event types, and severity levels are normalized.

3) Cross-Layer Correlation

- The system will then analyze the relationship between events in different layers using time relationships, behavioral relationships, and asset relationships. It is possible for unrelated events to be correlated as part of a suspicious lateral movement chain.

4) Risk Enrichment and Explanation

- The correlated events are then enriched with vulnerability data and fed into the XAI module, which generates explanations for the analyst about the risks and how they are determined to be malicious or of high risk.

5) Visualization and Analyst Output

- The dashboard displays the final correlated attack chain, associated vulnerabilities, and explanations for the analyst's review and analysis.

4.6 Scalability and Security Considerations

Scalability Considerations

The architecture that this research proposed should scale well to accommodate large hospital environments, which may involve lots of interconnected IoMT devices and systems. We may improve scalability by:

- having a module design so that every sub-component of the system may function independently
- having efficient distributed logging and processing
- having efficient event filtering before correlation
- having the ability to easily add new input sources without having to redesign the entire system

All these are important since hospitals may have hundreds or thousands of interconnected devices, user endpoints, and systems.

Security Considerations

As this part is dealing with critical security and infrastructure-related data, a set of security considerations is necessary for it:

- Secure storage of collected logs and alerts
- Strict control of access to the dashboard and backend modules
- Data encryption in transit and at rest
- Anonymization of critical identifiers when necessary
- Access control for analysts and administrators
- Audit trails for accessing the dashboard and performing system actions

This will prevent the component from becoming a weak link in the system as it processes critical healthcare security data.

5. USER REQUIREMENTS

Stakeholders

The system is designed for various stakeholders who manage and protect IoMT-based healthcare infrastructures. They use the system in unique ways depending on their roles and responsibilities.

Security Analysts

These are the main users. They monitor security alerts generated by security tools and investigate suspicious activities within the healthcare network. They will be able to identify correlated threat paths, movements within the network, and the assets at greatest risk within the IoMT-based network.

Hospital IT Administrators

IT administrators are in charge of managing the IT systems and devices within the hospitals. They will be able to identify vulnerabilities and security risks within the network and take appropriate measures to mitigate the identified vulnerabilities through the proposed system.

Cybersecurity Incident Response Teams

IR teams are in charge of handling cybersecurity incidents and mitigating ongoing attacks. They will be able to understand the nature and manner in which the attackers gained access to the healthcare network through the correlated threat paths and lateral movements within the network.

Healthcare System Managers / Decision Makers

These are the top management and decision-makers within the healthcare systems and cybersecurity industry. They will be able to understand the security position of the healthcare systems through the use of the proposed system's results.

Functional requirements (numbered)

The functional requirements specify what exact functionality is expected from the proposed component.

FR1:

The system will collect security alerts and event logs from various sources, including network monitoring tools, endpoint monitoring tools, authentication logs, and vulnerability assessment tools.

FR2:

The system will preprocess and normalize the collected security data in a standardized format to support cross-layer analysis.

FR3:

The system will correlate security events from different system layers to identify relationships between suspicious activities.

FR4:

The system will identify possible lateral movement patterns of interconnected IoMT devices and healthcare infrastructure.

FR5:

The system will utilize the results of vulnerability assessments to identify high-risk assets and suspicious attack paths.

FR6:

The system will provide explanations for detected attack chains using explainable AI.

FR7:

The system will provide correlated attack paths, detected anomalies, and identified vulnerable assets through an interactive security dashboard.

FR8:

The system will allow security analysts to query and investigate correlated security alerts and attack patterns through the interactive dashboard.

FR9:

The system will store processed security events and correlation results for further analysis and reporting.

Non-functional requirements

Non-functional requirements specify how well the system should be and any constraints involved in its use.

1. **Security Requirements**

NFR1:

Ensure that logs collected and results of analysis are stored in such a manner that no unauthorized access takes place.

NFR2:

Ensure that user authentication takes place for access to the dashboard.

NFR3:

Ensure that sensitive security data and logs are encrypted during transmission.

2. **Performance Requirements**

NFR4:

Ensure that security events are processed quickly and results of correlation are available in a timely manner for incident investigation.

NFR5:

Ensure that large amounts of security logs from IoMT devices and other components of the healthcare infrastructure are handled.

3. **Usability Requirements**

NFR6:

Ensure that results of correlated alerts, vulnerabilities, and attack paths are displayed in a clear manner in the dashboard.

NFR7:

Ensure that there are explanations provided for detected attack patterns so that security analysts understand the results of detection.

4. **Scalability Requirements**

NFR8:

Ensure that new log sources are easily handled for access to security data.

5. **Reliability Requirements**

NFR9:

Ensure that there is constant availability for monitoring and analyzing security events in the healthcare infrastructure.

6. COMMERCIALIZATION PLAN

6.1 Target Market and Customer Persona

The target market of the proposed system includes organizations whose environments are infused with Internet of Medical Things (IoMT) technologies. This includes hospitals and healthcare providers whose environments are infused with medical devices, medical imaging technologies, and clinical information systems. However, environments infused with such technologies are highly vulnerable to sophisticated cyber attacks such as fileless malware attacks and lateral movement attacks.

The target market includes

- Hospitals and Healthcare Networks
- Medical Research Institutes
- Diagnostic Laboratories
- Telemedicine Service Providers
- Healthcare Cybersecurity Service Providers

The customer personas of the proposed system are

- Hospital IT Security Administrators

These are administrators responsible for monitoring hospital environments. They are responsible for the security of medical devices and patient information. This persona needs a system capable of detecting abnormal device behaviors and cyber-attacks.

- Healthcare Cybersecurity Analysts

These are security analysts working in hospital security operations centers (SOC) responsible for analyzing security alerts to identify potential cyber-attacks.

- Medical Device Security Teams

These are teams responsible for the security of medical devices such as those infused with IoMT technologies.

6.2 Value Proposition

The proposed system provides a hybrid AI-based cybersecurity solution, particularly designed for IoMT in healthcare environments, overcoming the shortcomings of existing security monitoring systems.

The main value propositions are

- Multi-layer threat detection: The system can detect threats on multiple levels, including network, endpoint, predictive threat patterns, and cross-layer attack correlation.
- Detection of stealthy fileless malware attacks: The system will be particularly designed for detection of memory-based malware attacks, which are difficult for traditional antivirus software to detect.

- Cross-layer attack correlation: The system will be able to correlate attacks from different components, thus providing a comprehensive attack chain
- Explainable AI-based threat interpretation: The system will be able to explain threats detected, helping security analysts understand the rationale for the detection.
- Healthcare-specific cybersecurity protection: Unlike existing intrusion detection systems, the proposed system will be particularly designed for IoMT in healthcare environments, medical imaging, and hospital infrastructures.

6.3 Revenue Model

The proposed system has the opportunity for revenue generation based on the Software-as-a-Service (SaaS) or enterprise security solutions business model.

The possible revenue models for the proposed system are:

1. Subscription-Based Model

The proposed system has the opportunity for generating revenue by charging a subscription fee from the healthcare organizations that utilize the proposed system for their operations.

Example:

The proposed system has the opportunity for generating revenue by charging a subscription fee from the healthcare organizations that utilize the proposed system for their operations. The proposed system has the opportunity for generating revenue by charging a subscription fee from the healthcare organizations that utilize the proposed system for their operations.

2. Enterprise Licensing Model

The proposed system has the opportunity for generating revenue by allowing hospitals to purchase the proposed system for implementation in their hospital's internal cybersecurity infrastructure.

3. Security Monitoring Services

The proposed system has the opportunity for generating revenue by allowing security teams to utilize the proposed system for monitoring security threats.

4. Integration with Existing Security Platforms

The proposed system has the opportunity for generating revenue by allowing the integration of the proposed system into SIEM/SOC systems, which are utilized by cybersecurity vendors for their operations.

6.4 Pricing Strategy

The pricing strategy will be based on the tiered pricing model according to the complexity of the healthcare infrastructure.

Package	Targeted organization	Estimated Price
Basic	Small Clinic centers and laboratories	LKR.150,000.
Professional	Medium Size hospitals	LKR.450,000.
Enterprise	Large hospital networks	Customized price.

Table 4: Pricing Strategy for the Proposed Cybersecurity System

Additional services like advanced threat analysis, vulnerability assessment, security consulting services may be provided as premium features.

6.5 Competitive Advantage

The proposed system has several competitive advantages over existing cybersecurity solutions.

- Healthcare-specific security design

The cybersecurity solutions available in the market are generic and can be applied to any general enterprise network. The proposed system is specifically designed for an IoMT healthcare network.

- Hybrid multi-component architecture

The system comprises four different detection components. The combination of these components can provide a comprehensive detection capability for the different layers.

- Cross-layer attack correlation capability

Unlike existing intrusion detection systems, the proposed system can correlate the detected attacks across different layers.

- Explainable AI integration

The inclusion of an XAI dashboard can help in decision-making for cybersecurity analysts.

- Proactive threat forecasting

The inclusion of a predictive threat forecasting engine can help organizations forecast potential threats.

The proposed system can offer a comprehensive cybersecurity solution compared to an existing intrusion detection system or SIEM.

6.6 Intellectual Property Considerations

It is possible that the system may incorporate intellectual properties that can be protected under different intellectual property protection schemes.

Possible intellectual properties that may be protected include:

- Software Copyright Protection

It is possible that the software platform, as well as the algorithms for correlation, AI, and dashboard systems, may be protected under software copyright protection.

- 2. Patent Protection Opportunities

It is possible that certain technical aspects of the system may be patented, such as:

  - Cross-layer correlation algorithms for IoMT cybersecurity.
  - AI-based attack path reconstruction mechanisms.
  - Explainable AI dashboards for healthcare cybersecurity.

- 3. Trade Secrets Protection

It is possible that certain aspects of the system, such as:

  - Proprietary detection algorithms.
  - Threat correlation logic.
  - Predictive threat forecasting models

may be protected as trade secrets for commercialization purposes.

It is also necessary to ensure compliance with healthcare data protection regulations such as HIPAA-like regulations and national data protection policies when deploying the system in a real-world environment

8. WORK BREAKDOWN STRUCTURE (WBS)

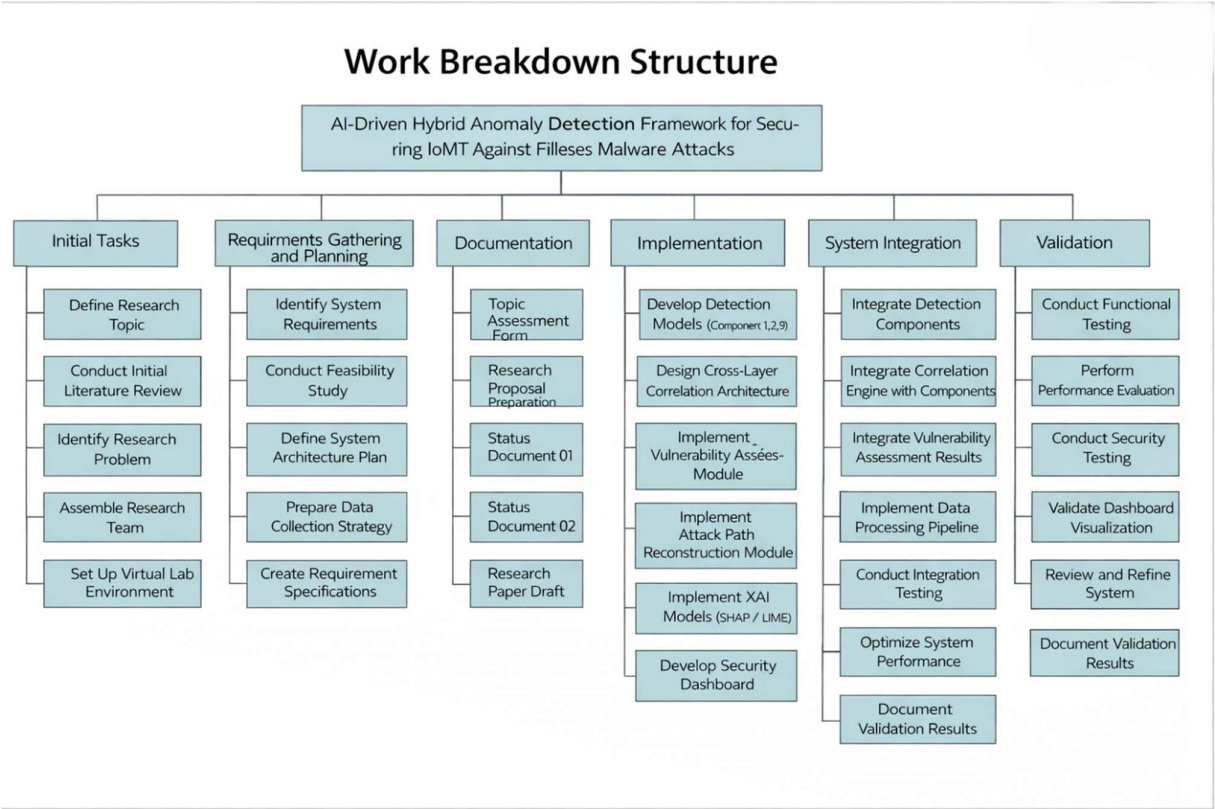


Figure 3: workbreakdown structure.

9. GANTT CHART

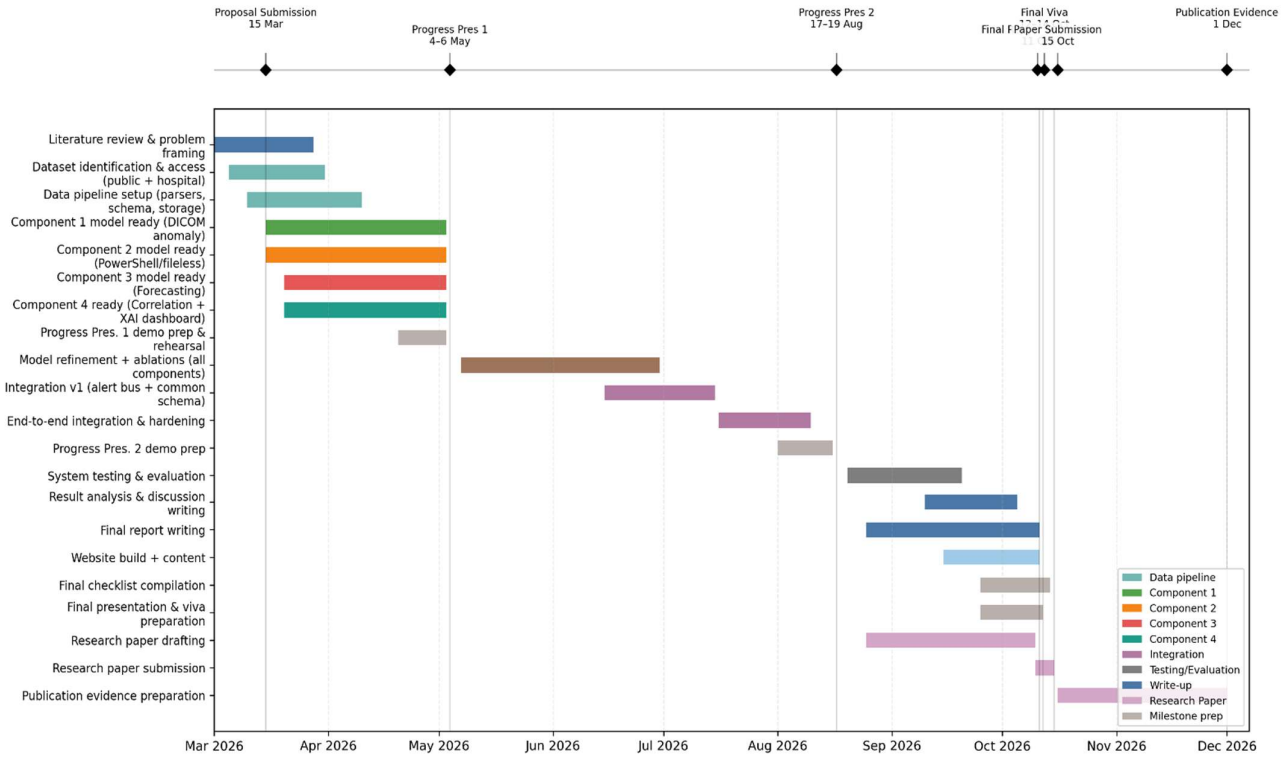


Figure 4:Overall research project gantt chart

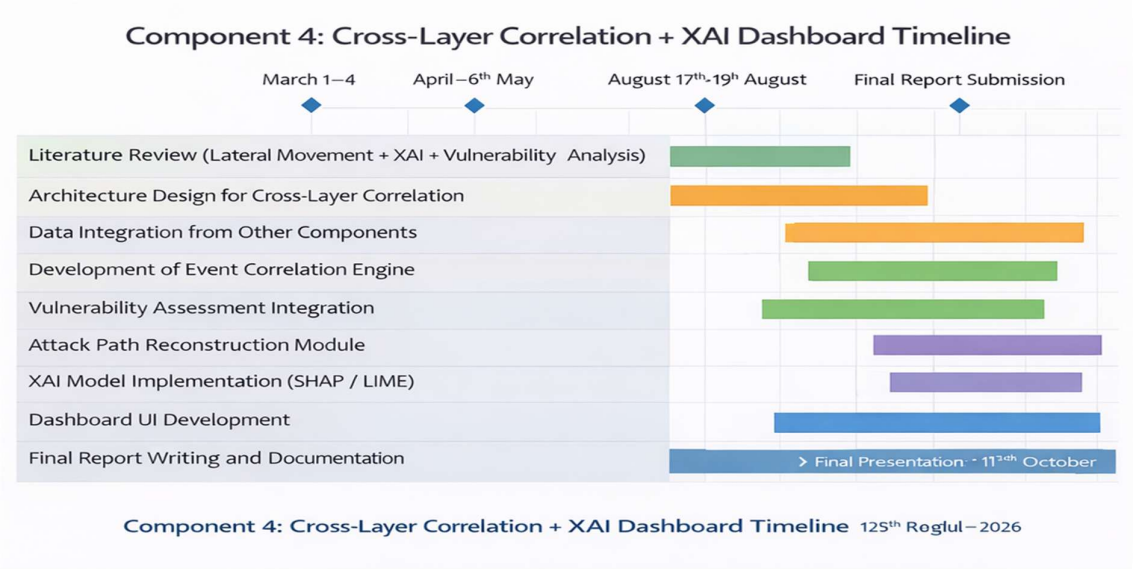


Figure 5: Component 4 gantt chart.

10.REFERENCES LIST

[1]Z. Zhang, Y. Zhang, X. Zhao and H. Chen, “Design and Data Analysis of Sports Information Acquisition System Based on Internet of Medical Things,” IEEE Access, vol. 8, pp. 84792-84805, 2020.

[2]A. Zimba, Z. Wang and M. Mulenga, “Crypto-Ransomware Attacks and Defense Mechanisms: A Survey,” IEEE Access, vol. 7, pp. 144389-144412, 2019.

[3]R. Vinayakumar, K. P. Soman and P. Poornachandran,“Deep Learning Approaches for Cyber Security Intrusion Detection: A Survey,”IEEE Access, vol. 7, pp. 41525–41550, 2019.

[4]M. Adil, M. K. Khan, N. Kumar, M. Attique, A. Farouk, M. Guizani and Z. Jin, “Healthcare Internet of Things: Security Threats, Challenges, and Future Research Directions,” IEEE Internet of Things Journal, vol. 11, no. 11, pp. 19046–19069, 2024.

[5]A. Alshamrani, S. Myneni, A. Chowdhary and D. Huang, “A Survey on Advanced Persistent Threats: Techniques, Solutions, Challenges and Research Opportunities,” IEEE Communications Surveys & Tutorials, vol. 21, no. 2, pp. 1851-1877, 2019

[6]IBM Security, “Cost of a Data Breach Report,” 2024

[7]A. Adadi and M. Berrada, “Peeking Inside the Black-Box: A Survey on Explainable Artificial Intelligence (XAI),” IEEE Access, vol. 6, pp. 52138-52160, 2018.

[8]M. Wang, K. Zheng, Y. Yang and X. Wang, “An Explainable Machine Learning Framework for Intrusion Detection Systems,” IEEE Access, vol. 8, pp. 73127-73141, 2020.

[9]A. A. Hady, A. Ghubaish, T. Salman, D. Unal and R. Jain, “Intrusion Detection System for Healthcare Systems Using Medical and Network Data: A Comparison Study,” IEEE Access, vol. 8, pp. 106576–106584, 2020.

[10]N. Capuano, G. Fenza, V. Loia and C. Stanzione, “Explainable Artificial Intelligence in CyberSecurity: A Survey,” IEEE Access, vol. 10, pp. 93575–93600, 2022.

[11]Z. Zhang, H. A. Al Hamadi, E. Damiani, C. Y. Yeun and F. Taher, “Explainable Artificial Intelligence Applications in Cyber Security: State-of-the-Art in Research,” IEEE Access, vol. 10, pp. 93104–93139, 2022

[12]V. Malamas, F. Chantzis, T. K. Dasaklis, G. Stergiopoulos, P. Kotzanikolaou, M. Douligeris and D. Gritzalis, “Risk Assessment Methodologies for the Internet of Medical Things: A Survey and Comparative Appraisal,” IEEE Access, vol. 9, pp. 40049–40075, 2021.

[13]O. S. M. B. H. Almazrouei, P. Magalingam, M. K. Hasan and M. Shanmugam, “A Review on Attack Graph Analysis for IoT Vulnerability Assessment: Challenges, Open Issues, and Future Directions,” IEEE Access, vol. 11, pp. 44350–44376, 2023.

[14]Microsoft, “What is Microsoft Defender XDR?” Microsoft Learn, 2024.

[15]Microsoft, “Automatic attack disruption in Microsoft Defender XDR,” Microsoft Learn, 2025.

[16]Splunk, “Implementing risk-based alerting,” Splunk Lantern.

[17]Splunk, “Analyze risk with risk-based alerting in Splunk Enterprise Security,” Splunk Documentation, 2025.

[18]Palo Alto Networks, “Causality view - Cortex XDR,” Cortex XDR Documentation, updated 2026.

[19]Palo Alto Networks, “What is Causality,” Cortex XSIAM Documentation.